TECHNICAL PENETRATION TESTING REPORT & CAPSTONE ASSESSMENT

By Fredrick Maina Wanjohi

Security Evaluation: Target Cohort

Target System:	Cohort (Hack The Box - 10.129.83.41)
Assessment Scope:	Full Infrastructure & Web Application PenTest
Assessment Date:	August 2026
Document Classification:	CONFIDENTIAL / TECHNICAL FINDINGS

1. Executive Summary

During our security evaluation of your web systems, we discovered critical security oversights that allow an unauthorized external visitor to completely take over your server. By tricking your public website into fetching internal addresses, we uncovered a hidden internal system and exploited an unauthenticated backdoor within it to control the server, ultimately elevating our access to full administrative privileges. To protect your business, you must immediately update your server software, enforce strict login requirements across all system features, and restrict how your website interacts with internal networks.

> **[EXECUTIVE BRIEFING]** BUSINESS RISK IMPACT: Complete server compromise from an external network position without credentials. Immediate action required.

2. Scope & Methodology

The assessment evaluated the target system Cohort (10.129.83.41) from an unauthenticated external perspective. Our methodology followed standard black-box penetration testing phases: reconnaissance, web application analysis, internal service discovery, vulnerability exploitation, and local privilege escalation auditing.

Key Tools Utilized:

• Nmap (v7.99): Network port scanning, service version detection, and TLS certificate inspection.

• Gobuster (v3.8.2): Directory and endpoint brute-forcing against web services.

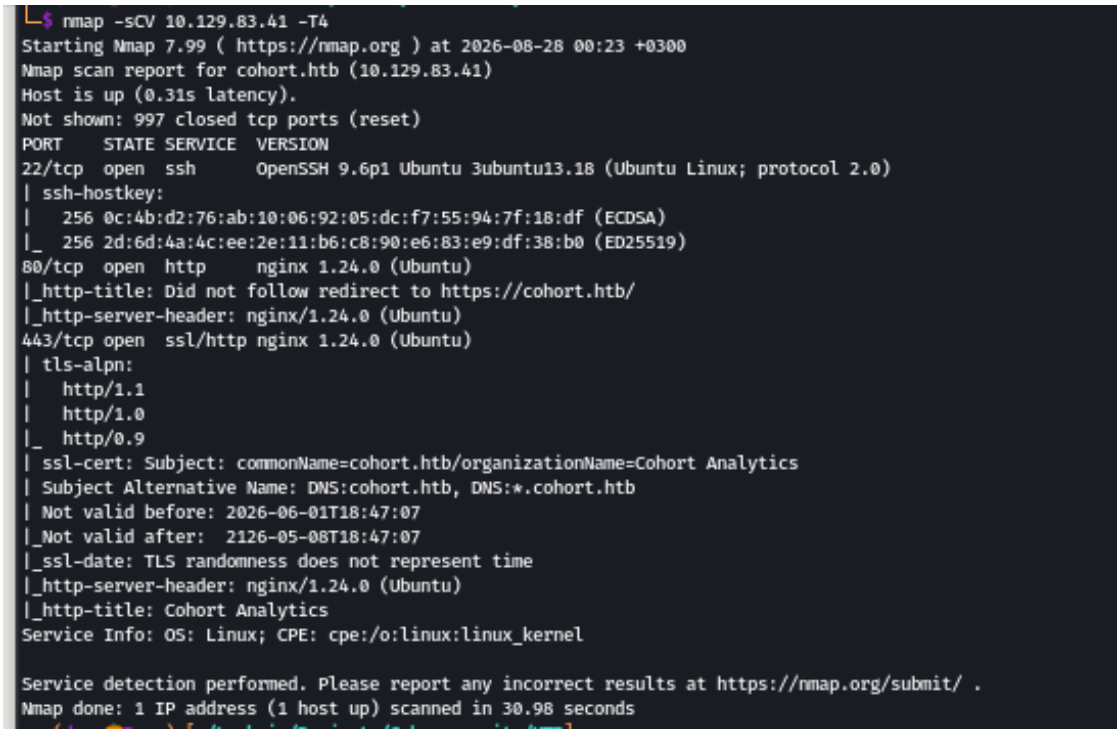
• Browser Developer Tools: Dynamic client-side Single Page Application (SPA) analysis and HTTP network tracing.

• Custom Python Scripts: Low-level TLS socket communication, raw WebSocket protocol frame handling, and D-Bus IPC interaction.

3. Reconnaissance & Enumeration Decisions

During this assessment, critical analytical decisions proved more vital than simply firing scanner commands:

1. Certificate SAN Analysis vs. Simple Scanning: An Nmap scan revealed ports 22, 80, and 443. Instead of focusing solely on the default web page, inspecting the TLS certificate revealed a Subject Alternative Name containing a wildcard (*.cohort.htb). Key Decision: Recognize that wildcard certificates mean virtual hosts/subdomains exist internally on the system, keeping subdomain discovery in mind throughout the web assessment.



```
└─$ nmap -sCV 10.129.83.41 -T4
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-28 00:23 +0300
Nmap scan report for cohort.htb (10.129.83.41)
Host is up (0.31s latency).
Not shown: 997 closed tcp ports (reset)
PORT    STATE SERVICE  VERSION
22/tcp  open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.18 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 0c:4b:d2:76:ab:10:06:92:05:dc:f7:55:94:7f:18:df (ECDSA)
|_  256 2d:6d:4a:4c:ee:2e:11:b6:c8:90:e6:83:e9:df:38:b0 (ED25519)
80/tcp  open  http     nginx 1.24.0 (Ubuntu)
|_http-title: Did not follow redirect to https://cohort.htb/
|_http-server-header: nginx/1.24.0 (Ubuntu)
443/tcp open  ssl/http nginx 1.24.0 (Ubuntu)
| tls-alpn:
|   http/1.1
|   http/1.0
|_  http/0.9
| ssl-cert: Subject: commonName=cohort.htb/organizationName=Cohort Analytics
| Subject Alternative Name: DNS:cohort.htb, DNS:*.cohort.htb
| Not valid before: 2026-06-01T18:47:07
|_Not valid after:  2126-05-08T18:47:07
|_ssl-date: TLS randomness does not represent time
|_http-server-header: nginx/1.24.0 (Ubuntu)
|_http-title: Cohort Analytics
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 30.98 seconds
```

Figure: Nmap Port Scan output revealing OpenSSH, Nginx web server, and TLS Certificate with Wildcard SAN (.cohort.htb).*

2. Dynamic Browser Execution vs. Static JS Reversing: Gobuster discovered /api, /assets, and /status (403 Forbidden). Viewing https://cohort.htb directly showed a Single Page Application (SPA) driven by an obfuscated JavaScript bundle (/assets/app.js). Key Decision: Rather than spending hours statically decompiling obfuscated JavaScript, leverage browser DevTools with 'Preserve log' to let the browser execute the app natively while observing network requests.



Figure: Gobuster directory scan discovering /api, /assets, and ACL-restricted /status endpoint.

3. Input Validation Bypass Strategy: Browsing the SPA revealed /portal.html ('Client Insights'), featuring a form to 'register and validate a report source URL'. Key Decision: Identify 'validate URL' as a server-side URL fetching feature (SSRF vector). When a naive loopback request (127.0.0.1) returned 'Internal or loopback addresses are not permitted', the error phrasing suggested a naive string blocklist rather than actual socket IP resolution. Testing shorthand IPv4 notation (127.1) bypassed the string check, echoing response previews.

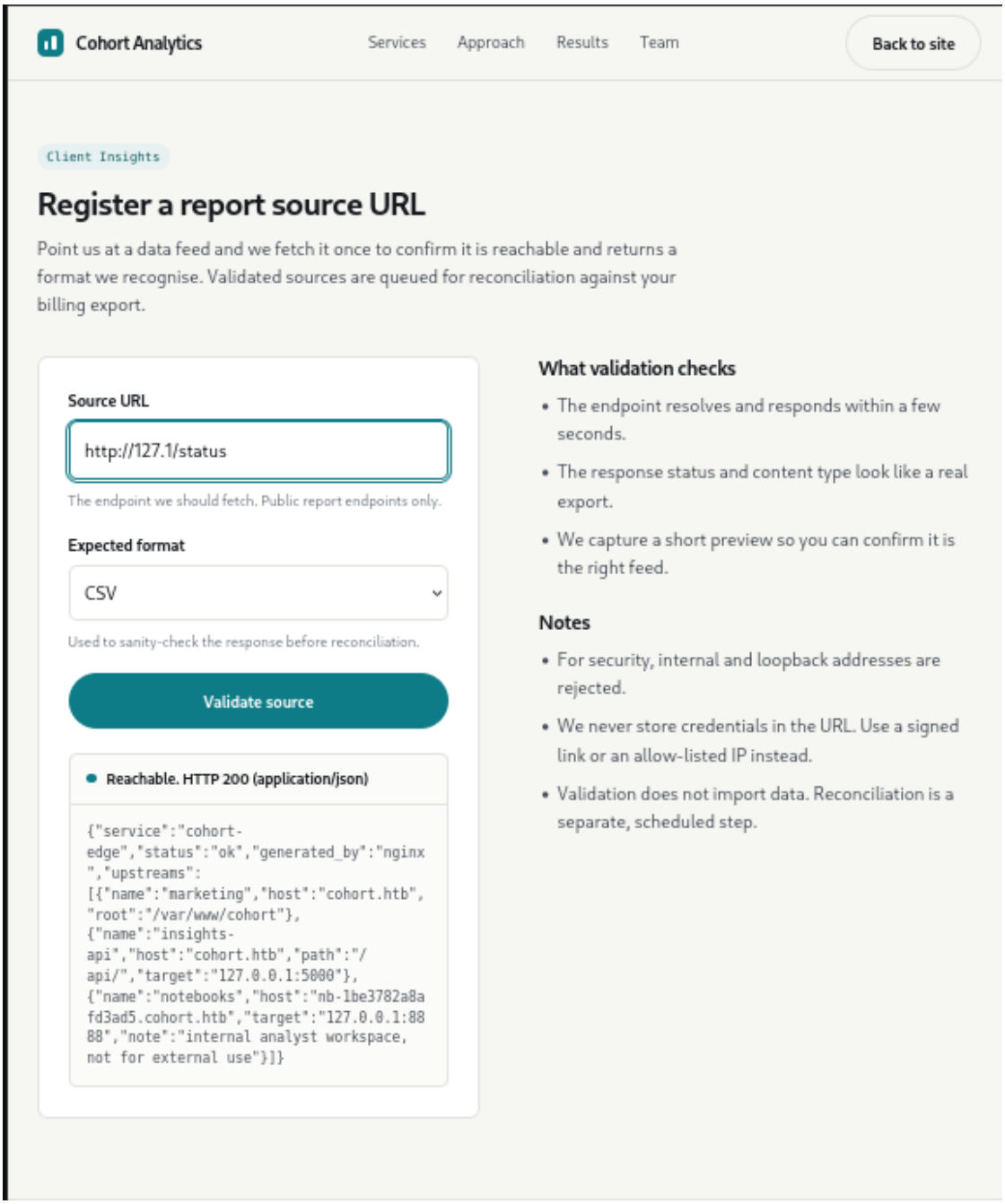


Figure: SSRF filter bypass via 127.1/status on Cohort Analytics Portal, exposing internal Virtual Host nb-1be3782a8afd3ad5.cohort.htb.

4. End-to-End Attack Chain

The compromise of Cohort was achieved through a sequential, interdependent attack chain where each link provided the exact prerequisite information or access primitive required for the subsequent step:

• **Link 1: External Nmap Reconnaissance:** Revealed port 443 with a wildcard TLS certificate (*.cohort.htb). This established that hidden virtual hosts existed on the server.

- **Link 2: SPA Endpoint Enumeration:** Discovered /portal.html featuring a URL validation utility ('Register a report source URL'), establishing a potential Server-Side Request Forgery entry point.
- **Link 3: SSRF IP Bypass & Response Leakage:** Exploited naive string filtering on /api/validate using 127.1/status. This bypassed boundary controls and leaked Nginx upstream configuration, revealing hidden internal vhost nb-1be3782a8afd3ad5.cohort.htb on port 8888.
- **Link 4: Internal Subdomain Mapping:** Mapped nb-1be3782a8afd3ad5.cohort.htb in local DNS. Navigating to the site revealed an internal Marimo Notebook application behind a password prompt.
- **Link 5: WebSocket Missing Authorization (CVE-2026-39987):** Exploited missing authentication on /terminal/ws using a raw Python socket script to establish a WebSocket shell. This yielded Remote Code Execution as user marimo and enabled reading user.txt.
- **Link 6: PackageKit TOCTOU Race (CVE-2026-41651):** Discovered D-Bus PackageKit service running as root. Triggered a TOCTOU race condition during InstallFiles transactions to execute maintainer scripts, generating SUID binary /tmp/.suid_bash to achieve root access.

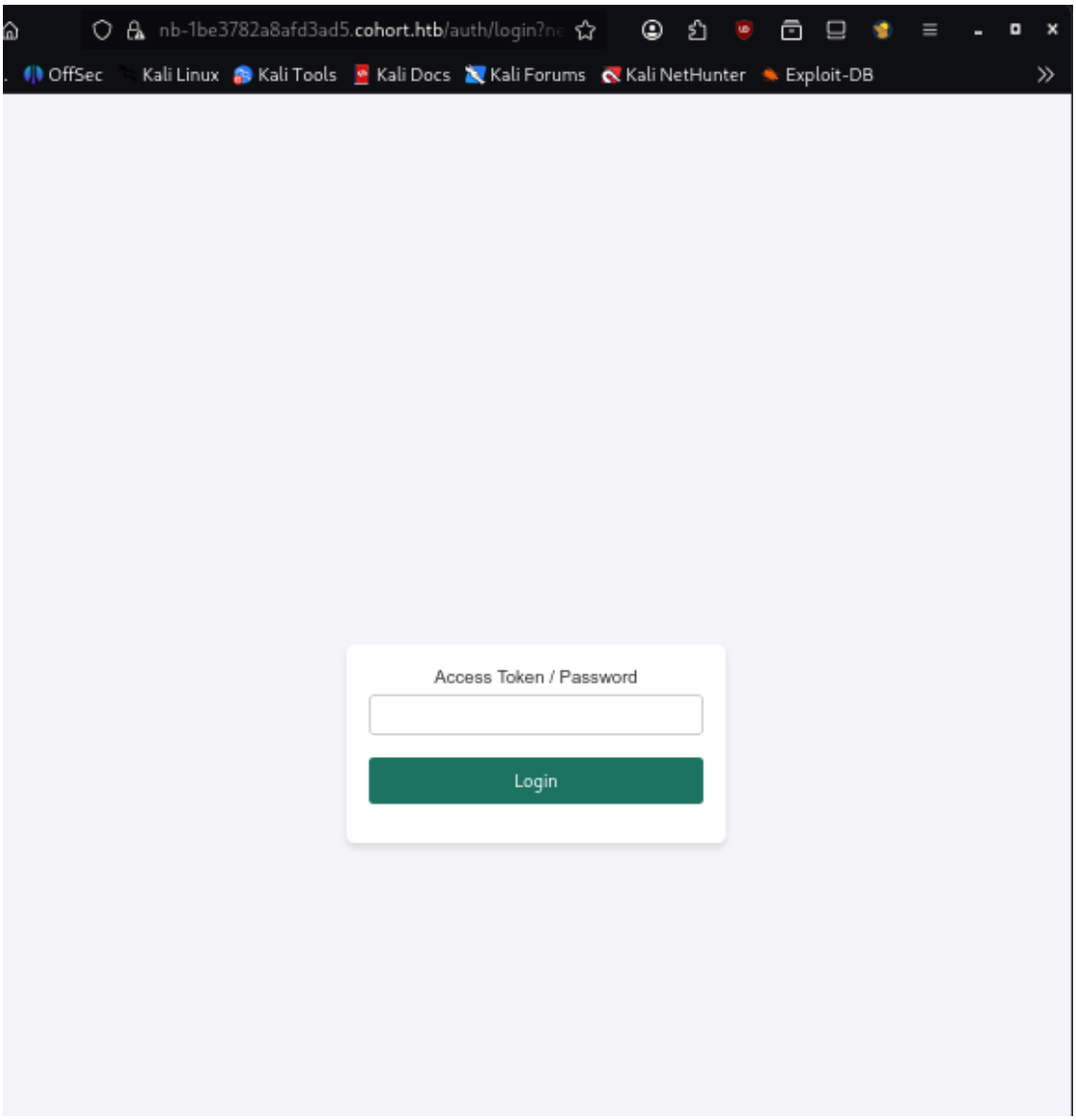


Figure: Accessing internal analyst workspace nb-1be3782a8afd3ad5.cohort.htb displaying Marimo login prompt.

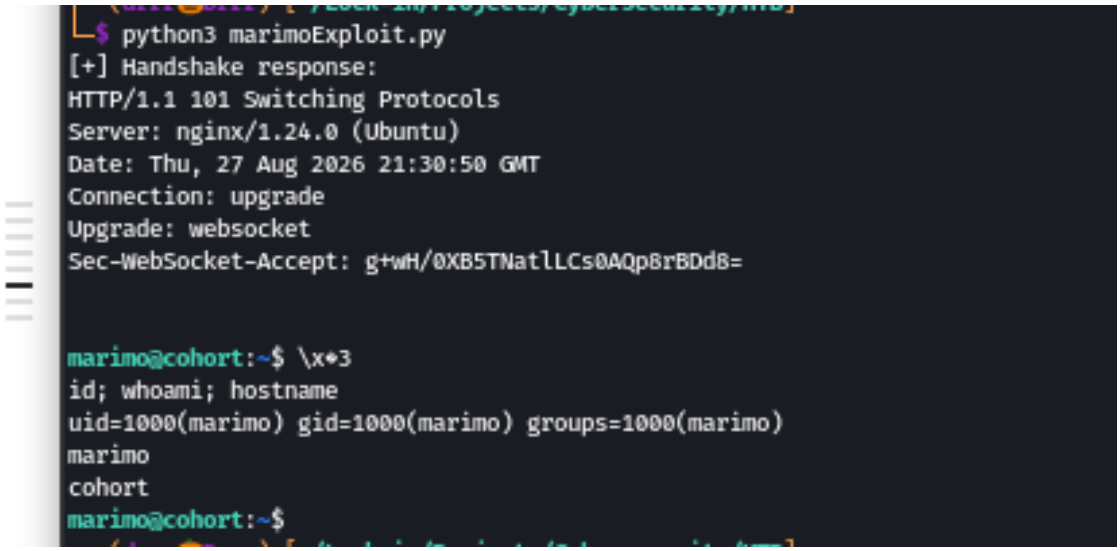


Figure: Executing Python WebSocket exploit to bypass Marimo authentication and obtain interactive shell as marimo.

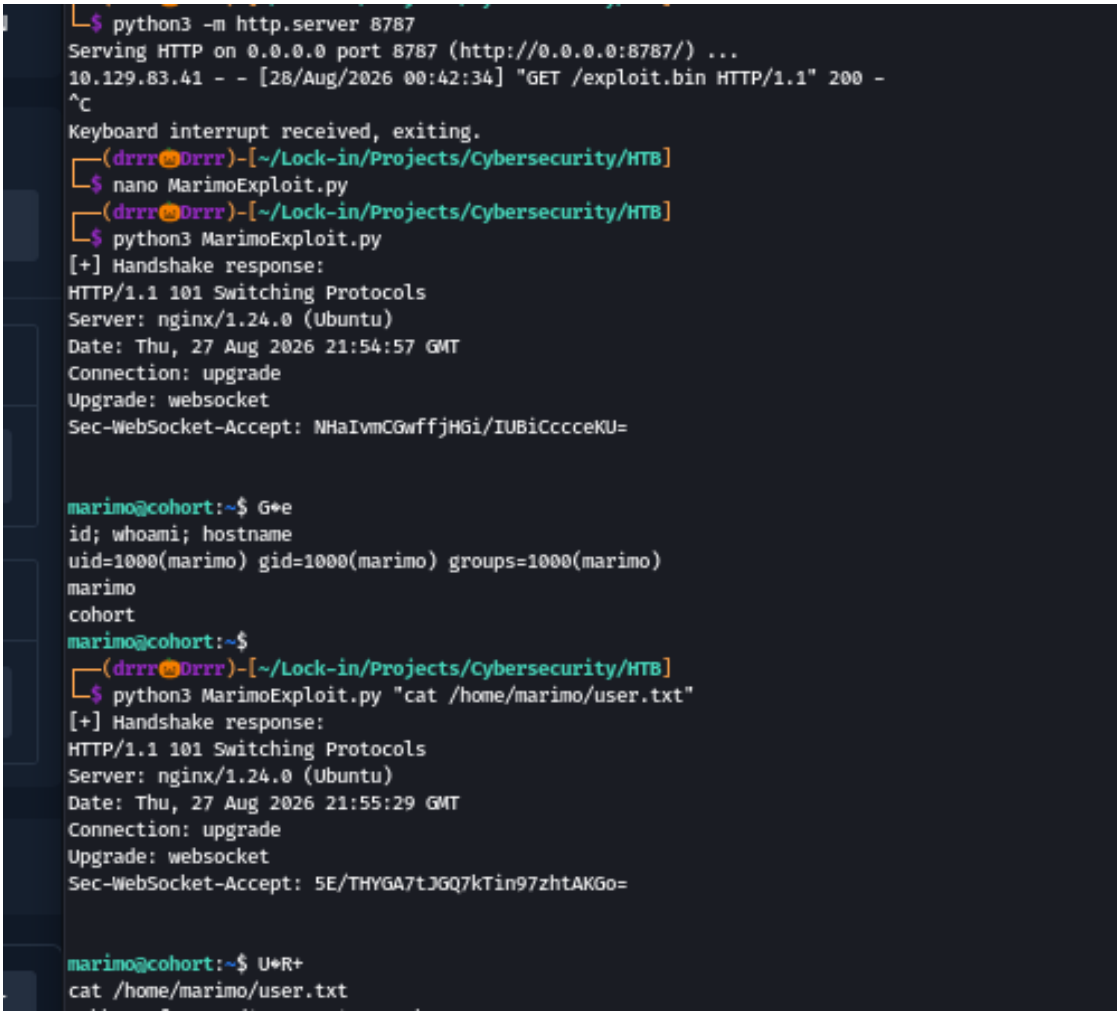


Figure: Retrieving user flag from /home/marimo/user.txt.

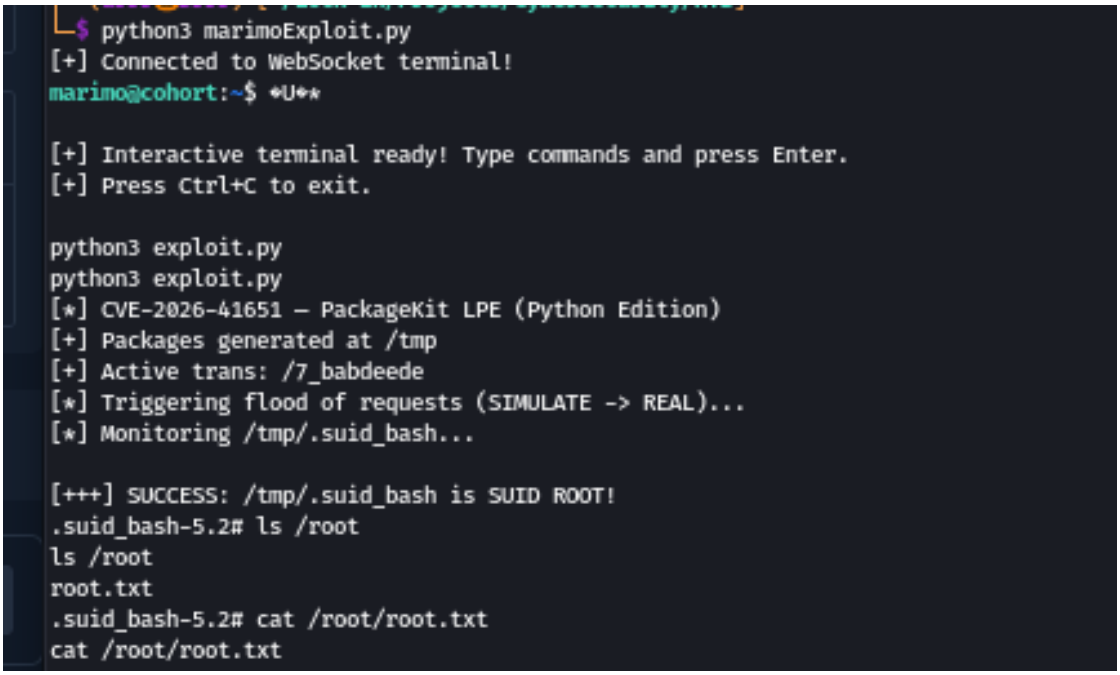


Figure: Winning PackageKit D-Bus race condition, creating SUID root binary /tmp/.suid_bash, and reading root.txt.

5. Deep Vulnerability Analysis

Finding 1: Naive String-Based SSRF Filter Bypass (No CVE)

Underlying Flaw: The validation engine performs string pattern matching against input URLs to check for strings like '127.0.0.1' or 'localhost' before making an HTTP request. However, operating system network libraries interpret shorthand IPv4 representations (such as 127.1, 0x7f.1, or 2130706433) as valid loopback addresses. Because the application validated raw text rather than resolving the destination IP at the socket layer, the security check failed entirely.

Finding 2: Missing Authorization on Marimo WebSocket Terminal (CVE-2026-39987)

Underlying Flaw: Marimo's web framework guards standard HTTP GET/POST endpoints behind an authentication session check (validate_auth()). However, when processing HTTP GET requests containing Upgrade: websocket headers targeting /terminal/ws, the router skips authentication middleware and immediately upgrades the HTTP socket into an unauthenticated raw WebSocket pseudoterminal connection.

Finding 3: PackageKit D-Bus TOCTOU Race Condition (CVE-2026-41651)

Underlying Flaw: PackageKit's root daemon accepts InstallFiles D-Bus calls with a SIMULATE flag for dry runs. Because transaction objects fail to lock parameter state during execution, an unprivileged user can open a transaction, submit a SIMULATE request, and rapidly overwrite transaction parameters with a real installation payload before the initial check completes. The root daemon proceeds to execute the maintainer scripts of the newly supplied package.

6. Vulnerability Findings Table

Issue Title	CVE Identifier	Severity	CVSS v3.1	One-Line Technical Summary
SSRF Filter Bypass	N/A (CWE-918)	HIGH	8.6	String-matching IP filter on /api/validate allows 127.1 loopback access.
Marimo Terminal RCE	CVE-2026-39987	CRITICAL	9.8	Missing authentication on /terminal/ws WebSocket allows unauthenticated RCE.
PackageKit TOCTOU LPE	CVE-2026-41651	HIGH	7.8	D-Bus InstallFiles race condition executes arbitrary deb postinst scripts as root.

7. Remediation & Strategic Defense Plan

Detailed Fix Matrix per Finding

• **Finding: SSRF Filter Bypass**
- Owner: Web Development Team
- Specific Fix: Refactor /api/validate to parse input URLs into canonical socket IP addresses before fetching, and reject any address resolving to RFC 1918 / RFC 5735 / loopback CIDR blocks.
- Verification Method: Issue curl requests targeting 127.1, 0x7f.1, 127.0.0.1, and private IPs (10.0.0.1); verify HTTP 400 rejection across all representations.

• **Finding: Marimo Terminal RCE (CVE-2026-39987)**
- Owner: System Administration / Analytics Team
- Specific Fix: Upgrade Marimo instance to patched version (> 0.1.0) with WebSocket authentication middleware enforced across all routes.
- Verification Method: Send raw WebSocket handshake GET /terminal/ws without auth cookie; verify server responds with 401 Unauthorized / 403 Forbidden.

• **Finding: PackageKit TOCTOU LPE (CVE-2026-41651)**
- Owner: Linux SecOps / Infrastructure Team
- Specific Fix: Upgrade PackageKit daemon via apt update && apt upgrade packagekit (> 1.3.4) and

restrict Polkit D-Bus transaction privileges for unprivileged users.
- Verification Method: Execute Pack2TheRoot D-Bus script on target; verify PackageKit rejects parameter modification and no SUID binary is created.

Policy vs. Architectural Design Analysis

• Caught by Patching Policy: Both CVE-2026-39987 (Marimo software update) and CVE-2026-41651 (PackageKit OS package update) would have been prevented by a routine monthly patch management policy.

• Required Architectural Design Change: The SSRF vulnerability on /api/validate and the exposure of port 8888 internally were design flaws. Even if Marimo had zero vulnerabilities, allowing an external web server to query arbitrary local ports via SSRF violates network boundary segregation. A proper design change requires moving analyst workspaces to an isolated subnet inaccessible from the edge web server.

> **[EXECUTIVE SINGLE PRIORITY RECOMMENDATION]** If the client can only fix ONE thing this quarter: Fix the SSRF Architecture & Network Isolation.
>
> Why: The SSRF vector is the single bridge between the public internet and internal server services. Fixing the SSRF and placing internal analyst tools on a separate subnet completely neutralizes the attack surface. Even if internal tools like Marimo contain zero-day vulnerabilities in the future, external attackers will have no network path to reach them.

8. Capstone Assessment Reflection

• Where I Got Stuck & Solutions:
1. Obfuscated Client JavaScript (30 mins): Initially spent time reading app.js manually. Resolved by pivoting to browser DevTools to monitor runtime network traffic.
2. Custom WebSocket Client Construction (45 mins): Standard Python websockets libraries failed over TLS reverse proxy sockets. Resolved by writing a low-level Python socket script with custom TLS wrapping and manual WebSocket frame masking.
3. PackageKit Privilege Escalation Execution (20 mins): Exploit binary hung waiting for an interactive TTY inside non-interactive WebSocket pipe. Resolved by executing the binary in the background (nohup) and invoking the resulting /tmp/.suid_bash with -p.

• What I Would Do Differently:
Start network tracing immediately on Single Page Applications rather than inspecting source code. Develop modular low-level socket templates earlier when encountering non-standard WebSocket endpoints.

• Knowledge Gaps Exposed for Future Study:

Deep-dive into D-Bus IPC system architecture and Polkit permission models. Advanced raw socket protocol crafting and custom RFC 6455 WebSocket implementation details in Python.